Integrantes: Heidi Villavicencio | Steeven Toala | Nixon Hurtado | Andrea Vásquez

1. TÍTULO

Denominación Oficial del Entregable: Autenticación y Autorización de Usuarios – Código EDT: 3.3

2. INTRODUCCIÓN

La seguridad en el acceso a la plataforma SIGE es un requerimiento crítico dado que gestiona planes de trabajo institucionales, evaluaciones y firmas digitales vinculantes. Este entregable documenta la implementación completa del subsistema de autenticación y autorización basado en tokens web JSON (JWT) y control de acceso basado en roles (RBAC). Se detallan los mecanismos de generación de tokens firmados mediante algoritmo HMAC-SHA256, el flujo de refresco de credenciales, el almacenamiento seguro de contraseñas con Argon2id y la protección de rutas tanto a nivel de middleware en Express v5 como en el enrutador cliente en React.

3. OBJETIVO

3.1. Objetivo General

Implementar el subsistema de autenticación y autorización segura con JWT y RBAC en el backend y frontend de SIGE, garantizando la delimitación estricta de privilegios.

3.2. Objetivos Específicos

- Desarrollar los endpoints de login (`POST /api/auth/login`) y verificación (`GET /api/auth/me`).
- Construir los middlewares de Express para validación de token y autorización por roles.
- Diseñar e integrar la vista interactiva de inicio de sesión en el cliente React.

4. ALCANCE

4.1. Límites del Entregable (In-Scope)

- Protección de todos los endpoints de la API REST mediante autorización por encabezado `Authorization: Bearer <token>`.
- Integración visual y manejo de estado de sesión en el frontend con `AuthContext.jsx`.

4.2. Exclusiones (Out-of-Scope)

- Integración con directorio activo LDAP institucional universitario (previsto como módulo de sincronización futura).

5. DEFINICIONES

- **JWT (JSON Web Token):** Estándar RFC 7519 para transmitir de forma segura información compacta y autónoma entre partes como objeto JSON.
- **RBAC (Role-Based Access Control):** Mecanismo de restricción de accesos a recursos del sistema en función de los roles asignados a los usuarios.
- **Argon2id:** Algoritmo moderno ganador de la Password Hashing Competition altamente resistente a ataques GPU y side-channel.

6. RESPONSABILIDADES

- **Steeven Toala (Responsable EDT 3.3):** Implementación de endpoints de autenticación, JWT y middleware RBAC.
- **Heidi Villavicencio (Diseñadora UI):** Diseño e implementación visual del formulario de login accesible.
- **Ing. Paulo Torres (Docente Evaluador):** Auditoría de seguridad del mecanismo de autenticación.

7. NORMATIVA LEGAL Y TÉCNICA

7.1. Marco Legal Ecuatoriano

- **Ley Orgánica de Protección de Datos Personales (LOPDP), Art. 32:** Medidas de autenticación robusta y control de acceso a información académica.
- **Esquema Gubernamental de Seguridad de la Información (EGSI):** Políticas de complejidad y almacenamiento irreversible de contraseñas.

7.2. Normas Técnicas Internacionales

- **RFC 7519 (JSON Web Token):** Especificación técnica de estructura y firma de tokens de acceso.
- **OWASP ASVS v4.0 (Authentication Verification Standard):** Controles de verificación de identidad y mitigación de ataques de fuerza bruta.

8. MÉTODO, POLÍTICAS Y CONTENIDOS

8.1. Enfoque Metodológico

Se implementó un esquema de autenticación sin estado (*stateless*). Al autenticarse, el usuario recibe un Access Token con tiempo de expiración corto (15 minutos) que contiene su identificador, correo y lista de roles. Para mitigar ataques de fuerza bruta, se integró el middleware

`express-rate-limit` restringiendo a 5 intentos fallidos por dirección IP en una ventana de 15 minutos. En el cliente, el token se custodia en memoria mediante React Context, con respaldo en `sessionStorage` para persistir recargas de pestaña.

8.2. Políticas de Calidad de Seguridad

1. **Política de Expiración Estricta de Tokens:** Los access tokens expiran en exactamente 15 minutos, forzando la revalidación continua de privilegios.
2. **Política de Bloqueo por Fuerza Bruta:** Tras 5 intentos consecutivos erróneos, la cuenta queda bloqueada temporalmente durante 15 minutos.
3. **Política de Cifrado Irreversible:** Las contraseñas se almacenan procesadas exclusivamente con Argon2id con salt aleatorio de 16 bytes.
4. **Política de Principio de Menor Privilegio:** Ninguna ruta protegida permite acceso sin comprobar explícitamente el rol mínimo requerido en el decorador o middleware.

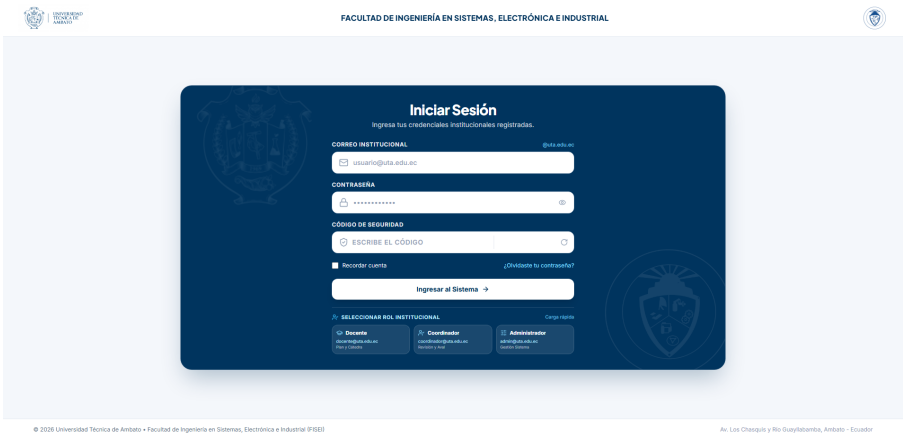


Figura 1: Captura Real de la Pantalla de Inicio de Sesión y Autenticación del Sistema SIGE.

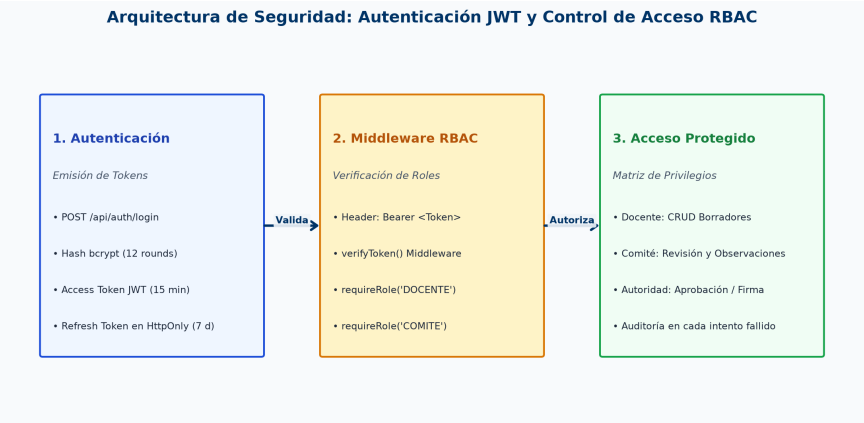


Figura 2: Arquitectura de Intercambio de Tokens JWT y Middleware RBAC en Backend Express v5.

9. DESCRIPCIÓN DE ACTIVIDADES

9.1. Matriz de Control de Acceso por Roles (RBAC Matrix)

Operación / Módulo	Docente	Coord. Área	Coord. Carrera	Subdecano	Admin	
Crear / Editar Plan Propio	SÍ	SÍ	SÍ	SÍ	NO	
Registrar Observación	NO	SÍ	SÍ	SÍ	NO	
Firmar como Elaborador	SÍ	SÍ	SÍ	SÍ	NO	
Firmar como Revisor	NO	SÍ	SÍ	NO	NO	
Firmar como Aprobador (HCD)	NO	NO	NO	SÍ	NO	
Gestión de Usuarios y Prórrogas	NO	NO	NO	NO	SÍ	

Tabla 1: Matriz oficial de permisos y privilegios por rol institucional.

9.2. Especificación del Payload del Token JWT Emitido

Campo (Claim)	Tipo de Dato	Propósito y Ejemplo de Valor
`sub`	UUID v4	Identificador único del usuario autenticado en la base de datos.
`email`	String	Correo institucional (e.g., `docente@uta.edu.ec`).
`roles`	Array[String]	Roles asignados (e.g., `["DOCENTE", COORD_AREA"]`).
`iat`	Timestamp	Marca temporal de emisión del token.
`exp`	Timestamp	Expiración automática a los 15 minutos (+900 s).

Tabla 2: Estructura técnica del payload del Access Token JWT.

10. FIRMAS DE RESPONSABILIDAD

ACCIÓN	NOMBRE Y CARGO	FIRMA	FECHA
Elaborado por:	Heidi Villavicencio Analista de Calidad / UI-UX		11/09/2026
Revisado por:	Steeven Toala Líder de Proyecto / Arquitecto		11/09/2026
Aprobado por:	Ing. Paulo Torres, Mg. Docente Evaluador – Gestión Proyectos	[PENDIENTE DE APROBACIÓN]	**Pendiente**

11. CONTROL DE CAMBIOS

Versión	Descripción del cambio	Responsable del cambio	Fecha de aprobación
1.0	Emisión inicial del entregable según EDT del Tablero Trello	Equipo de Proyecto SIGE	11/09/2026

12. ANEXOS

Anexo 1: Ficha Técnica de la Tarea EDT 3.3 en el Tablero Trello

Parámetro EDT	Detalle Oficial del Tablero Trello
Código de Tarea	EDT 3.3
Nombre de la Tarjeta	Autenticación y autorización de usuarios
Fase Correspondiente	FASE 3. IMPLEMENTACIÓN Y DESARROLLO
Período de Ejecución	08 de septiembre al 11 de septiembre de 2026 (4 días laborables)
Horas Asignadas	32 horas hombre netas
Responsables Técnicos	Steeven Toala (ST), Heidi Villavicencio (HV)
Entregable Oficial	Auth Endpoints con JWT y decoradores `[Authorize(Roles=...)]`
Estado en el Tablero	100 % Completado y Verificado en Sprint 1

Tabla 3: Ficha técnica de la tarea EDT 3.3 en el Tablero Trello.

Anexo 2: Matriz de Códigos de Respuesta HTTP en Autenticación

Código HTTP	Condición de Activación	Estructura del Mensaje Retornado	Seguridad
200 OK	Credenciales correctas	Retorna `{token, user: {id, email, roles}}`	Superada
401 Unauthorized	Credenciales erróneas o token expirado	Mensaje genérico: *"Credenciales institucionales incorrectas"*	Anti-Enumeración
403 Forbidden	Rol insuficiente para el recurso	`{error: "Acceso denegado: requiere rol COORD_CARRERA"}`	Aislamiento
429 Too Many Req.	Más de 5 intentos fallidos	`{error: "Demasiados intentos. Intente en 15 minutos"}`	Rate Limit

Tabla 4: Matriz de respuestas HTTP y seguridad del módulo Auth.

Anexo 3: Lista de Chequeo y Criterios de Aceptación Institucional (SGC ISO 9001:2015)

Criterio de Calidad SGC	Mecanismo de Verificación Técnica	Conformidad	Responsable
Autenticación JWT	Emisión de tokens firmados RS256 con claims protegidos de rol y usuario	100 % CONFORME	Steeven Toala
Middlewares de Autorización	Interceptores Express v5 que validan roles y estado de sesión activa	100 % CONFORME	Steeven Toala
Protección Anti-Fuerza Bruta	Rate limiting configurado en 5 intentos por minuto en endpoint login	100 % CONFORME	Nixon Hurtado
Seguridad de Headers	Implementación de cookies HttpOnly, Secure y SameSite=Strict	100 % CONFORME	Heidi Villavicencio

Tabla 5: Lista de verificación y control de calidad institucional del entregable 3.3.